



Clarification Questions - Pear

Instructions
Please use the table below to submit any clarification questions.

Answers sourced from prior RFP/Security questionnaires and then edited for accuracy. Sourcing tool: <https://chatgpt.com/g/g-68e4583b0fa08191be4b30ba035a26d9-pear-commerce-rfp-tech-questionnaire-helper>

Role	Topic	Question	Answer
Cybersecurity	Salsify Connector/API	Can the Pear team provide a technical drawing with explanation how the application integrates with Salsify?	<u>Diagram:</u> https://drive.google.com/file/d/1c59gRIh7KHXj8g8ktCJIS_Lt0xrn5onw/view?usp=drive_link <u>Explanation:</u> <u>Salsify (PIM) exports CSV delta files (only changed items) via SFTP to Pear’s secure inbox.</u> <u>A scheduled ingest job picks up each file, validates headers/rows, and normalizes fields (GTIN/UPC, title, size, images).</u> <u>Validated changes are written into the Pear Catalog with logs and error alerts for any rejected rows.</u> <u>The live Pear Catalog then powers Where-to-Buy experiences and shoppable ads (SKU mapping, availability, add-to-cart).</u> <u>Security: SFTP in transit, encrypted at rest; optional PGP file encryption if required.</u>
Privacy	IP Tracking	Can the Pear team explain more how IP tracking works, can it be turned off? This may require a bit of a demo.	How IP tracking works: When a shopper loads a Pear experience (store locator, shoppable PDP, landing page, or in-ad Pear Connect), our event pipeline creates a single page-load record. That record currently includes an ip field along with derived geo (city/state/ZIP), device, UTM, retailer, SKU, and conversion timestamps. What it is used for: - Session quality & fraud controls (bot filtering, duplicate session heuristics). - Geolocation fallback (deriving city/state/ZIP if a user hasn’t given location permission). - Attribution hygiene (deduping unusual traffic bursts from single network egress points). What it is not used for: - Not shared to ad platforms or used to build audiences. Pixels & audience building use click events only itself, not ip address. - Not used to identify named individuals. - Not used to enrich PII. - Not used to train any third-party AI model Demo Data: ip = "203.0.113.57" city="Austin" state="TX" zip="78701" Can it be turned off: You may opt not to save IP address. In that case, a user will always need to first select a location before interacting with Pear UX, and some core fraud detection and attribution hygiene features will be limited or disabled.
Privacy	Pixel	Does Pear have it's own pixel?	Pear does not have any pixels of their own, but Pear experiences can host pixels.

Link to edit diagram: <https://app.eraser.io/workspace/X83uRPGTB7aMuAkSZn1f>

Legal	Intellectual Property	Will Pear be utilizing existing McCormick content (recipes, etc.) in order to provide the services? Will any new content be generated by Pear?	Pear will only use McCormick-provided or McCormick-approved content; Pear will not author new consumer-facing copy. For recipe add-to-cart experiences, existing McCormick content is parsed to build the recipe add-to-cart UX, but there will not be net-new content generated.
Privacy	GDPR	What categories of personal data are collected as part of this service (e.g., IP address, location, device data)?	A) Online identifiers - IP address (pseudonymous): used for session quality / fraud controls and (optionally) coarse geolocation. - Cookies / session IDs (first-party): for de-duplication, frequency capping, and attribution. - Device identifiers from UA (non-persistent): browser/OS family, device type (desktop/mobile/tablet). B) Approximate location data - Coarse geo (city/region/ZIP), derived from User-provided ZIP or browser geolocation (with consent), or IP-based lookup. - No precise movement tracking; no continuous location history. C) Technical/telemetry data - Timestamped event logs: page views, retailer selections, add-to-cart clicks, purchase callbacks. - HTTP metadata: referrer URL, page URL, campaign parameters (UTM_source/medium/campaign/content/term). D) Commerce context (non-PII) - Product identifiers: UPCs/SKUs viewed or added, quantities - Retailer routing: selected retailer/store, fulfillment mode (pickup/delivery/ship). What we do not collect: - No direct identifiers: no names, emails, phone numbers, postal addresses. - No payment data or full order details (checkout occurs with retailers). - No special-category data (Art. 9).

			Yes — limited data is shared with specific processors, strictly to deliver the service 1) Internal Hosting & observability Who: Cloud + tooling (e.g., AWS for hosting; Datadog; GitHub). What: Service telemetry/ops data; we don't store client-scoped PII in these systems 2) IP -> coarse geo resolution Who: An IP-to-geo provider (e.g., MaxMind) What: Shopper IP solely to return coarse location (city/region/ZIP). Our event schema contains ip and zip fields used for this purpose. 3) Maps & geocoding tiles Who: A map/tiles provider (e.g., Stadia Maps) to render store locators. What: Map tile and geocoding requests using coarse location inputs (ZIP/city or map viewport) to draw the map; no names/emails are sent. 4) Retailers & last-mile purchase tracking Who: Retailers' ecommerce platforms/APIs and affiliate networks (e.g., Walmart, Target, Impact). What: Click-through/add-to-cart events and purchase callbacks that let us attribute sales (session-level, not cardholder data). 5) Ad platforms and analytics providers (only if you provide pixels) Who: Your Ad platforms or analytics services (e.g., Meta/TTD/LiveRamp/Google pixels). What: Standard pixel events (view, retailer_select, add_to_cart, purchase) to measure results and/or build audiences. No card data or direct identifiers from Pear.
Privacy	GDPR	Is any of the data shared with or transferred to other entities (e.g., subcontractors, map providers, analytics companies)?	
Security GRC	Encryption	What encryption Key is used to encrypt data at rest and data in transit? Per McCormick policy a minimum of TLS 1.2 or higher for data in transit and AES 256-bit for data at rest.	Encryption in Transit: HTTPS is used for all public endpoints and APIs using TLS 1.2 or higher (TLS 1.3 where supported). Encryption at Rest: Data stores are encrypted at rest with AES-256 using our cloud provider's managed encryption (KMS-backed). Encryption keys are generated, stored, rotated, and retired in accordance with industry standards and cloud-provider KMS controls.
Security GRC	Pen Test Report	Please could you share with us your most recent penetration test report?	
Security GRC	Document	Do you have any Pear security whitepaper you could share?	

			Yes Pear has a patch management program. Scope & coverage: - Servers & containers: OS packages, container base images, and app dependencies. - Cloud-managed services: managed DBs, load balancers, runtimes (patched by the cloud provider; we track advisories and apply required engine upgrades). - Third-party libraries: automated dependency alerts and PRs (e.g., GitHub Dependabot) with build-time policy checks. - Network & edge: CDN/cache layers kept on provider-supported, auto-updated channels. Cadence & SLAs: - Critical: patch or mitigate within 7 days in production (24–72h with emergency change if practical). - High: within 30 days. - Medium: within 90 days. - Low: within 180 days (or by next planned maintenance). Process Controls: - Automated detection: weekly scans of images, hosts, and code dependencies. - Phased rollout: dev -> staging -> production with canary/blue-green deploys and rollback procedures. - Change management: peer review + approvals for production changes; maintenance windows for non-emergencies. - Verification: post-patch scans, health checks, and monitoring; periodic penetration testing validates coverage.
Security GRC	Patch management	Is there a patch management program in place?	
Security GRC	Access control	Do you support Single Sign-On (SSO) via SAML 2.0?	Yes. Pear supports Single Sign-On (SSO) via SAML 2.0 using Auth0 enterprise connections (SP-initiated), with standard attribute mapping.
			Yes. Pear operates a Data Loss Prevention program made up of policy, process, and technical controls. Policy & governance: - Enterprise security & access control programs with owned, reviewed policies and periodic access reviews. - Information classification with approved handling rules (encryption, storage, transmission). - Retention & destruction requirements (live, backup/archived media, and subcontractors). Technical controls: - Encryption in transit for all electronic transfers. - Email security/DLP: inbound/outbound email scanning with phishing prevention. - Network intrusion detection to monitor and block suspicious activity. Process controls: - Change management for production systems (prevents accidental exposure). Scope & data posture: - We do not store regulated/confidential scoped data for this service, minimizing DLP surface area.
Security GRC	DLP	Do you have a Data Loss Prevention program in place?	

